

9 DoS Attacks

Learning objectives

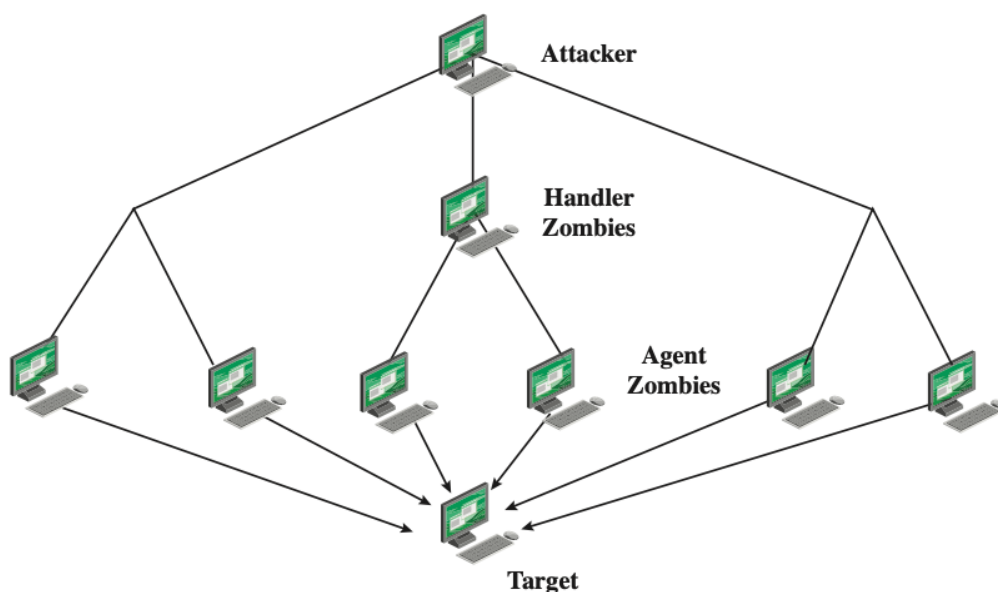
- Explain the basic concept of a DoS attack and how to defense it.
- Explain SYN-flooding attacks and detecting & preventing methods.
- Learn about the nature of flooding attacks, reflector and amplifier attacks

DoS攻击概述与DDoS架构

DoS 全称: Denial-of-Service

- A form of attack on the availability of some service
- Categories of resources that could be attacked are:
 - Network bandwidth
 - Relates to the capacity of the network links connecting a server to the Internet
 - System resources
 - Aims to overload or crash the network handling software
 - Application resources
 - Typically involves a number of valid requests, each of which consumes significant resources, thus limiting the ability of the server to respond to requests from other users
- **核心概念:** DoS (Denial-of-Service, 拒绝服务) 攻击本质上是一种针对系统或服务**可用性 (Availability)** 的攻击形式。
- **三大攻击目标:**
 - **网络带宽 (Network bandwidth):** 试图过载连接服务器与互联网之间的网络链路。
 - **系统资源 (System resources):** 旨在让处理网络请求的软件过载或崩溃。
 - **应用资源 (Application resources):** 通过发送大量看似“有效”的请求, 耗尽服务器处理能力, 使其无法响应其他正常用户的请求。

Distributed Denial of Service (DDoS) Attack



- **分布式拒绝服务 (DDoS)**: 攻击者 (Attacker) 利用控制节点 (Handler) 操控海量的“僵尸主机 (Zombies/Agents) ”, 同时向同一个目标 (Target) 发起DoS攻击, 从而产生压倒性的破坏力。

Classic DoS Attack: Flooding 基础泛洪攻击

例如使用连续的 `ping` 命令生成大量数据包, 目的是压垮目标网络连接的容量。但这种直接攻击很容易暴露攻击者的真实身份, 且目标服务器的响应包也会消耗攻击者自身的网络性能。

- Aim of this attack is to overwhelm the capacity of the network connection to the target organization
- Flooding ping command
 - Source of the attack is clearly identified
 - Response packets affect the network performance of the source system

Source Address Spoofing 源地址欺骗

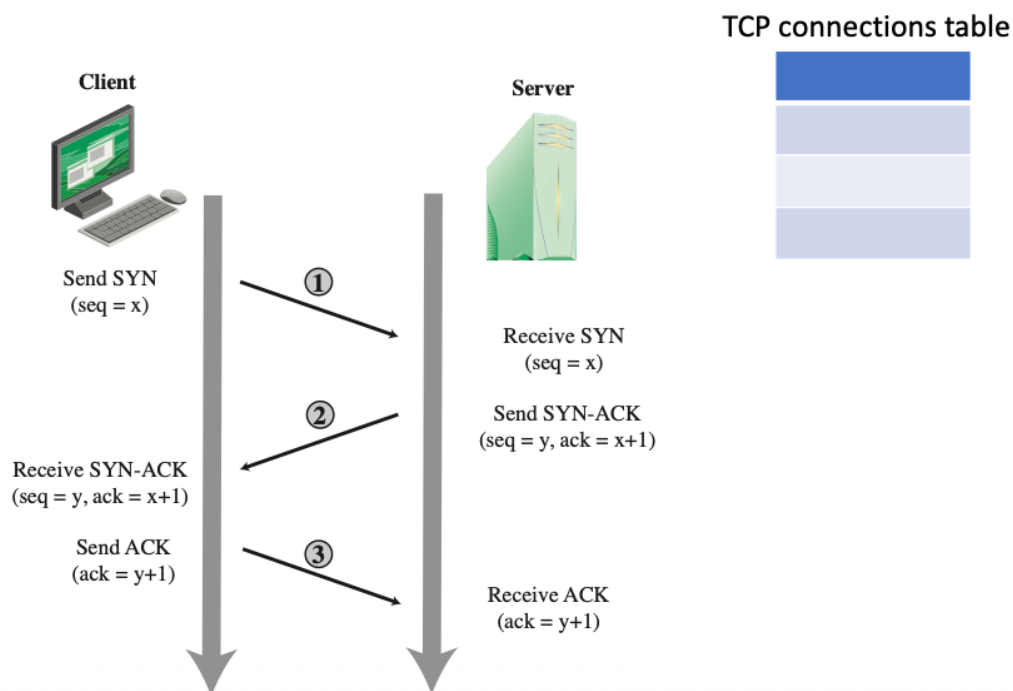
为了隐蔽自身, 攻击者会**伪造数据包的源IP地址** (通常伪装成目标系统的地址)。这不仅让防御方极难追踪攻击的真实来源, 还会导致目标服务器的响应包 (如ICMP echo回显) 无法返回给真正的攻击者。

- Use forged source addresses
使用伪造的源地址
- Attacker generates large volumes of packets that have the target system as the destination address
攻击者生成大量以目标系统为目的地址的数据包
- Harder to identify the attacking system
更难识别攻击系统
- ICMP echo response packets no longer be reflected back to the source system
ICMP 回显响应数据包将不再被反射回源系统。

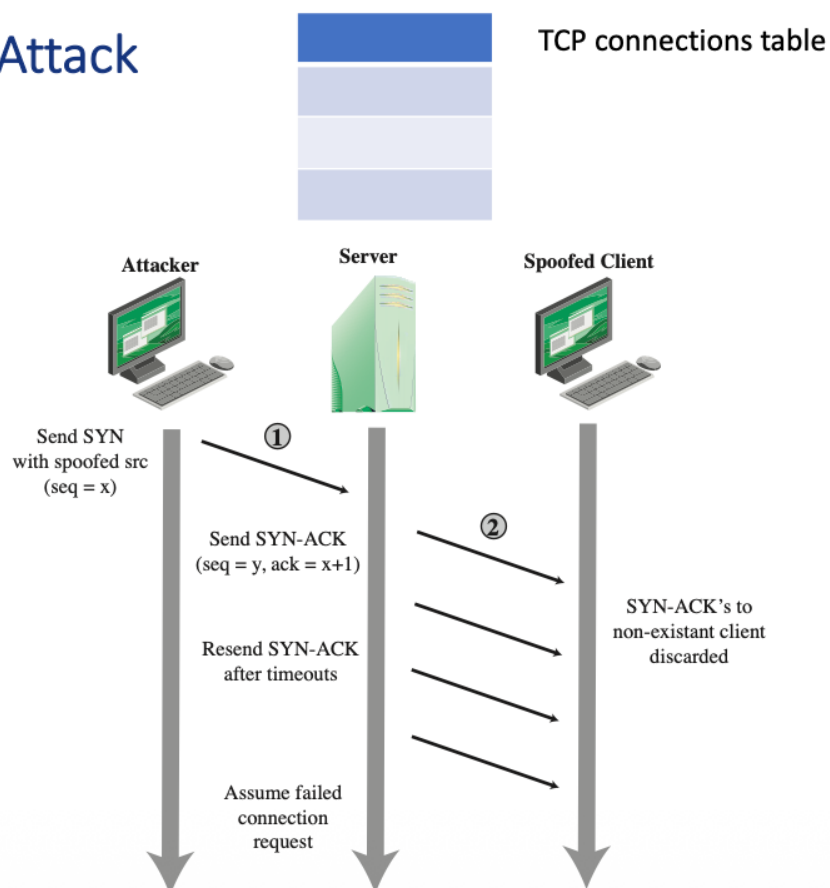
SYN Flooding SYN泛洪攻击

这种攻击针对操作系统中管理网络连接的代码, 利用了TCP协议的“三次握手”机制。攻击者发送大量带有伪造源IP的 `SYN` 请求, 服务器收到后会回复 `SYN-ACK`, 并在“TCP连接表”中预留资源等待最后一步确认。由于源IP是假的, 服务器永远等不到最终的 `ACK` 确认, 导致连接表被这些“半开连接”塞满, 合法的用户请求因此被拒绝。

- Common DoS attack
- Attacks the ability of a server to respond to future connection requests by overflowing the tables used to manage them
- Thus legitimate users are denied access to the server
- Hence an attack on system resources, specifically the network handling code in the operating system



TCP SYN-Flooding Attack



Detecting a SYN-flooding attack

检测方法：可以通过监控异常数量的“半开连接”、分析网络中源自特定IP的海量 `SYN` 数据包，或者使用统计学方法识别流量分布的异常来发现此类攻击。

- Monitoring Incomplete Connections:
 - look for a high number of half-open connections (where a SYN has been sent but no ACK has been received).
- Traffic Analysis:
 - Analyzing network traffic for a large number of SYN packets originating **from a single or multiple IP addresses**.
 - Statistical Analysis: Use statistical methods to analyze network traffic and identify **abnormal distributions** that may indicate a SYN flood.

Preventing a SYN-flooding attack 防范SYN泛洪的核心技术

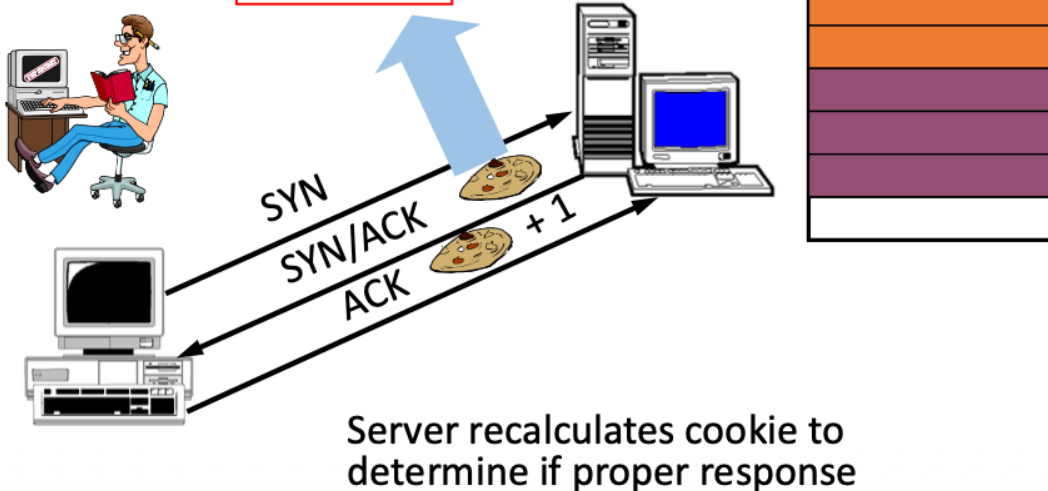
- SYN Cookies
 - SYN cookies are a technique used by servers to accept incoming TCP connections **without allocating memory for the connection until the connection is completed**. This prevents the attacker from overwhelming the server's resources with half-open connections.
 - Details in next slide.
- Rate limiting
 - Implement rate limiting on SYN requests at the network perimeter. This can be done using firewall rules or dedicated security appliances to limit the number of new connections that can be initiated from any single IP address within a certain time frame.
- **速率限制 (Rate limiting)：**在防火墙或网络边界设备上设置规则，限制特定时间内单个IP地址可以发起的新 `SYN` 连接数量。
- **SYN Cookies 技术：**这是一种非常巧妙的防御机制。当服务器收到 `SYN` 请求时，**不再像传统方式那样立即分配内存**。相反，它会将客户端IP、端口、时间戳等信息作为变量，计算出一个加密的哈希值（即Cookie），并将这个值作为 `SYN/ACK` 包的序列号发送出去。**关键点在于服务器不需要保存这个Cookie值**，只有当真实的客户端返回正确的 `ACK` （包含该Cookie+1的值）时，服务器重新计算并验证无误后，才会真正分配内存建立连接。

TCP SYN cookies

SYN/ACK number is secret
function of various **information**

Client IP address &
port, server's IP
address and port,
and a timer

KEY POINT: Server
doesn't need to
save cookie value!



Application-Based Bandwidth Attack 基于应用程序的带宽攻击

- Strategy: force the target to execute resource-consuming operations
 - HTTP: Hypertext Transfer Protocol
 - HTTP flooding attacks the web servers with requests
 - E.g., an HTTP request to download a large file
- 这种攻击的策略是强迫目标服务器执行极其消耗资源的操作。
- 典型的例子是 **HTTP泛洪攻击**：攻击者并非单纯用数据包堵塞网络，而是向Web服务器发送合法的HTTP请求，例如要求服务器“下载一个极其巨大的文件”，以此来榨干服务器的应用层处理能力。

Reflection Amplification Attacks 反射攻击

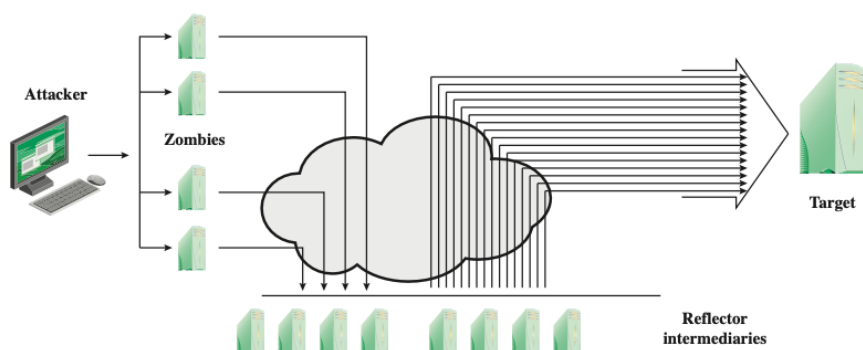
- Attacker sends packets to a known service on the **intermediary** with a **spoofed source address of the actual target system**
- When intermediary responds, the response is sent to the target
- “Reflects” the attack off the intermediary (reflector)
- Goal is to generate enough volumes of packets to flood the link to the target system without alerting the intermediary
- The basic defense against these attacks is blocking spoofed-source packets

反射攻击 (Reflection)：攻击者向互联网上正常的服务节点（即中间人/反射器）发送请求，但将数据包的源IP伪造成受害者的IP地址。反射器在处理完请求后，会将响应数据直接发送给受害者。这不仅达到了隐藏攻击者的目的，还能在不惊动反射器的情况下对目标形成流量泛洪。基础防范方法是在网络层面拦截伪造源IP的数据包。

Amplification Attack 放大攻击

这是反射攻击的恶劣变种。一般的反射攻击通常是“一个请求对应一个响应”，而放大攻击利用了某些协议的特性（如DNS放大攻击），使得反射回去的响应包体积远远大于原始的请求包，或者利用广播地址使得一个请求能够引发多个响应包，从而对受害者造成成倍的流量打击。

- A variant of reflector attacks.
- Difference
 - Reflection: usually a single request leads to a single response packets;
 - Amplification: a single request may lead to multiple response packets.



Strategy 1:

E.g., DNS Amplification

The response is typically much larger in size than the original query

Strategy 2:

Using broadcast address

DoS Attack Defenses

课件最后指出，**DoS攻击是无法被彻底且完全阻止的**。其根本原因在于，在现实世界中，瞬间的“极高流量”往往是合法的——例如某个网站突然爆红，或是发生了备受公众瞩目的突发事件。服务器在面对流量洪峰时，极难完美区分哪些是正常用户的热情访问，哪些是黑客精心伪装的拒绝服务攻击。

- These attacks cannot be prevented entirely
- High traffic volumes may be legitimate
 - High publicity about a specific site
 - Activity on a very popular site